FLORERÍA V'LIRIO · HOJA DE RUTA

Seguridad y nuevas funcionalidades

Documento de trabajo para revisar y verificar con el equipo. Cada punto tiene una prioridad, un esfuerzo estimado, un criterio para saber que está terminado, un espacio para el responsable y una casilla para marcarlo.

Punto de partida (10/11/2026)

Sitio estático en **Astro 5** publicado en **Cloudflare**. No tiene backend ni cobra en línea: el pedido termina en un enlace de WhatsApp. La canasta y los favoritos viven en el navegador (localStorage). El número de WhatsApp sale de la rama al construir (main: número del cliente · dev: número de pruebas). Lo previsto: **Supabase** para clientes y pedidos y una **pasarela de pago** (Culqi, Mercado Pago o Izipay).

Prioridades:

Crítica bloquea la fase si falta · Alta hacer pronto · Media planificar · Baja cuando haya tiempo

1. Seguridad

Fase 1 · Hoy (sitio estático)

ID	QUÉ	PRIORIDAD	ESFUERZO	CÓMO SE VERIFICA	RESP.	OK
S1	**Cabeceras HTTP de seguridad** Archivo **_headers** en Cloudflare: Content-Security-Policy (solo scripts y fuentes propios, GSAP y el mapa de Google), HSTS, X-Content-Type-Options, Referrer-Policy y Permissions-Policy.	Alta	Bajo	Nota A o superior en securityheaders.com y Mozilla Observatory. Sin errores de CSP en la consola en el home, el catálogo y el detalle.		☐
S2	**Prevenir XSS** Revisar todo uso de **innerHTML** con datos del usuario (dedicatoria de la canasta, parámetros de la URL). Usar **textContent** o escapar.	Alta	Bajo	grep de innerHTML sin datos del usuario. Escribir <script> o <img onerror> en la dedicatoria y en ?categoria= no ejecuta nada.		☐
S3	**Dependencias al día** npm audit en cada PR y Dependabot o Renovate en GitHub. Entender el riesgo de la cadena de suministro.	Media	Bajo	npm audit sin vulnerabilidades altas ni críticas. Dependabot activo y abriendo PRs.		☐
S4	**Secretos fuera del código** Nada sensible en el repo ni en variables PUBLIC_*: todo lo que llega al navegador es público.	Alta	Bajo	Secret scanning de GitHub activo. Sin .env en el historial. Las claves privadas solo como secretos de Cloudflare.		☐

Fase 2 · Con Supabase (clientes y pedidos)

ID	QUÉ	PRIORIDAD	ESFUERZO	CÓMO SE VERIFICA	RESP.	OK
S5	**Row Level Security (RLS)** En Supabase la llave anon es pública: cada tabla necesita políticas que limiten quién lee o escribe qué.	Crítica	Medio	Con la llave anon y curl NO se pueden listar, editar ni borrar pedidos de otros clientes. RLS activado en el 100% de las tablas.		☐
S6	**Autenticación y sesiones** JWT, cookies HttpOnly + Secure + SameSite. No guardar tokens en localStorage.	Alta	Medio	Ningún token visible en localStorage o sessionStorage. La sesión expira y se renueva correctamente.		☐
S7	**Validar en el servidor** No confiar en el navegador: el servidor recalcula precios y totales con Zod o funciones de la base de datos.	Crítica	Medio	Enviar un pedido con precio alterado (S/1) desde DevTools termina rechazado o recalculado.		☐

Fase 3 · Con pagos en línea

ID	QUÉ	PRIORIDAD	ESFUERZO	CÓMO SE VERIFICA	RESP.	OK
S8	**Nunca tocar datos de tarjeta** Usar el formulario o los tokens de la pasarela (Culqi, Mercado Pago o Izipay) para quedar fuera del alcance de PCI DSS.	Crítica	Medio	Ningún número de tarjeta pasa por nuestro servidor ni por nuestros logs (revisar las peticiones de red).		☐
S9	**Webhooks firmados e idempotentes** Un pedido se marca como pagado solo con el webhook firmado de la pasarela, nunca porque lo diga el navegador.	Crítica	Medio	Un webhook sin firma válida se rechaza. El mismo webhook enviado dos veces no duplica el pedido.		☐
S10	**Freno a bots y abuso** Rate limiting en las APIs y Cloudflare Turnstile en los formularios.	Media	Bajo	100 envíos seguidos del formulario quedan bloqueados. El captcha aparece solo cuando hace falta.		☐

Recursos para aprender

OWASP Top 10: owasp.org/Top10: el mapa de los riesgos web más comunes.
OWASP Cheat Sheet Series: cheatsheetseries.owasp.org: guías puntuales de XSS, CSP, sesiones y más.
Supabase · Row Level Security: supabase.com/docs/guides/database/postgres/row-level-security
Cloudflare Pages · _headers: developers.cloudflare.com/pages/configuration/headers
Medición: securityheaders.com · developer.mozilla.org/observatory

2. Nuevas funcionalidades

Corto plazo · Sin backend

ID	QUÉ	PRIORIDAD	ESFUERZO	CÓMO SE VERIFICA	RESP.	OK
F1	**Favoritos sincronizados y «Mis favoritos»** Sincronizar los favoritos entre pestañas, como la canasta, y una página para verlos y compartirlos por WhatsApp.	Media	Bajo	Marcar un favorito en una pestaña lo actualiza en la otra. La lista se comparte con un enlace.		☐
F2	**Fecha y zona de entrega en la canasta** Selector de fecha, horario y distrito, que se suma al mensaje de WhatsApp. Necesita las zonas, el costo y el horario del cliente.	Alta	Medio	El mensaje de WhatsApp incluye la fecha y la zona. No se pueden elegir fechas pasadas ni zonas sin cobertura.		☐
F3	**Personalizar el arreglo** Color del papel, tarjeta y extras (peluche, chocolates), con el precio actualizado en vivo.	Media	Medio	El total y el mensaje de WhatsApp reflejan cada opción elegida.		☐
F4	**Ocasiones y SEO local** Páginas por ocasión («flores para aniversario en Comas») y datos estructurados Product y LocalBusiness.	Alta	Bajo	Rich Results Test de Google sin errores. Las páginas aparecen en Search Console.		☐
F5	**Analítica sin cookies** Cloudflare Web Analytics para saber qué productos se ven y se piden más.	Media	Bajo	Panel con visitas por página. Sin banner de cookies necesario.		☐

Mediano plazo · Con Supabase

ID	QUÉ	PRIORIDAD	ESFUERZO	CÓMO SE VERIFICA	RESP.	OK
F6	**Panel de administración** Que la florería cambie productos, precios, stock y ofertas sin tocar código. Es la funcionalidad de más valor para el negocio.	Alta	Alto	El cliente crea un producto y cambia un precio solo, y se ve en la web sin un deploy manual.		☐
F7	**Registro de pedidos** El pedido se guarda antes de abrir WhatsApp, con un número para hacer seguimiento.	Alta	Medio	Cada mensaje de WhatsApp lleva un número de pedido que existe en la base de datos.		☐
F8	**Estado del pedido** El cliente consulta «en preparación», «en camino» o «entregado» con su número.	Media	Medio	El cambio de estado en el panel se ve en la página de seguimiento.		☐
F9	**Recordatorios de fechas especiales** El cliente registra un aniversario o cumpleaños y recibe un aviso unos días antes. Genera compras repetidas.	Media	Medio	Una fecha de prueba genera el recordatorio en el día configurado.		☐

Largo plazo

ID	QUÉ	PRIORIDAD	ESFUERZO	CÓMO SE VERIFICA	RESP.	OK
F10	**Pago en línea** Yape y tarjeta vía Culqi o Izipay. Depende de S8 y S9.	Alta	Alto	Pago de prueba en el sandbox aprobado y el pedido marcado como pagado solo por el webhook.		☐
F11	**Confirmaciones automáticas por WhatsApp** WhatsApp Business Cloud API para avisar del pago, la preparación y la entrega.	Media	Alto	El cliente recibe el mensaje automático al cambiar el estado del pedido.		☐
F12	**Puntos y cupones** Programa de fidelidad para clientes frecuentes.	Baja	Alto	Un cupón válido descuenta en el servidor. Uno vencido o usado se rechaza.		☐

3. Orden recomendado

#	CUÁNDO	QUÉ	POR QUÉ
1	**Esta semana**	S1 cabeceras · S2 XSS · S3 dependencias · S4 secretos	Sin backend, bajo esfuerzo y gran impacto.
2	**Próximas 2–4 semanas**	F2 fecha y zona · F4 SEO local · F5 analítica · F1 favoritos	Mejoran la venta sin backend. F2 depende del cliente.
3	**Antes de Supabase**	Estudiar S5 RLS, S6 sesiones y S7 validación	Diseñar la seguridad antes de escribir la base de datos.
4	**Fase Supabase**	F6 panel · F7 pedidos · F8 estado · F9 recordatorios	Con S5–S7 aplicados desde el primer día.
5	**Fase pagos**	S8 · S9 · S10 y luego F10 · F11 · F12	Primero la seguridad de pagos; después el cobro.

Recomendación: empezar por **S1 (cabeceras)** esta semana, seguir con **F2 (fecha y zona)** y estudiar **RLS** antes de escribir la primera tabla de Supabase.

4. Decisiones pendientes con el cliente

- ☐ Zonas de delivery, costo por zona y horario de atención (bloquea F2).
- ☐ Ofertas reales: qué productos llevan descuento y de cuánto (hoy son de ejemplo, demo: true).
- ☐ Logo en SVG o PNG transparente, y eslogan definitivo.
- ☐ Usuarios exactos de Facebook, Instagram y TikTok.
- ☐ Historia de la marca para «Nosotros».
- ☐ ¿Dominio propio? (por ejemplo vlirio.pe). Mejora el SEO y la confianza.

5. Ajustes menores detectados

- ☐ A 900px de ancho el header corta el botón «Mi canasta».
- ☐ En móvil el panel de filtros abre con «Ocasión» desplegado: evaluar empezar con todo cerrado.
- ☐ Hero del home de unos 2,3 pantallas en móvil: acortarlo y mostrar los botones desde el inicio.

Notas de la reunión

Fecha: _____ Asistentes: _____